ordinary access through a read-write or read-only capability will only see read-only message links.

Listing 9.7 Enforcing consistent permissions

```
var perms = request.<String>attribute("perms") #A
.replace("w", ""); #B
response.status(200);
return new JSONArray(messages.stream()
.map(msgId -> "/spaces/" + spaceId + "/messages/" + msgId)
.map(path ->
capabilityController.createUri(request, path, perms)) #C
.collect(Collectors.toList()));
```

#A Lookup the permissions from the current request.
#B Remove any permissions that are not applicable.
#C Create new capabilities using the revised permissions.

Update the remaining methods in the SpaceController.java file to return appropriate capability URIs, remembering to follow POLA. The GitHub repository accompanying the book (https://github.com/NeilMadden/apisecurityinaction) has completed source code if you get stuck, but I'd recommend trying this yourself first.

EXERCISES

3. The capability tokens use never-expiring database tokens. Over time this will fill the database with tokens. Which of the following are ways you could prevent this?

a) Hashing tokens in the database